AURELIUS DIGITAL SYSTEMS PVT. LTD.

IDENTITY, ACCESS MANAGEMENT & ACCEPTABLE TECHNOLOGY USE STANDARD

IAM-STD-03 | Version 7.0

Field	Controlled value
Document ID	IAM-STD-03
Version	7.0
Effective date	2026-08-01
Review date	2027-07-31
Classification	CONFIDENTIAL
Owner	Karan Shah (VP, Corporate Technology & Workplace IT)
Approver	Vikram Iyer (CTO), with Nikhil Varma (CISO) concurrence
Department	Corporate Technology & Workplace IT / Information Security & Resilience
Applicability	All workers, identities, accounts, endpoints, SaaS, remote access, and company/client technology use within scope
Status	APPROVED - CONTROLLED INTERNAL DOCUMENT

Fictional enterprise notice: Aurelius Digital Systems Pvt. Ltd., its identities, systems and internal rules in this document are fictional.

Document Control

IAM-STD-03-DC01 - Document-Control Record

Field	Controlled value
Document ID	IAM-STD-03
Title	Identity, Access Management & Acceptable Technology Use Standard
Version	7.0
Status	Approved - Controlled Internal Document
Effective date	2026-08-01
Review date	2027-07-31
Owner	Karan Shah (VP, Corporate Technology & Workplace IT)
Approver	Vikram Iyer (CTO), with Nikhil Varma (CISO) concurrence
Department	Corporate Technology & Workplace IT / Information Security & Resilience
Classification	CONFIDENTIAL
Applicability	All workers, identities, accounts, endpoints, SaaS, remote access, and company/client technology use within scope
Controlled repository	VaultPoint DMS
Distribution	Authorized workforce and functions according to classification and applicability
External-law treatment	Where a decision depends on external law or a client obligation not contained here, obtain verified guidance from Legal & Corporate Affairs.

Revision History

IAM-STD-03-RH01 - Revision History

Version	Effective / status	Meaningful change
5.0	Prior controlled release	Initial controlled issue and consolidation of predecessor guidance.
5.5	Prior controlled release	Expanded scope, roles and source-of-truth controls.
6.0	Prior controlled release	Aligned enterprise systems, approval vocabulary and document interfaces.
6.4	Prior controlled release	Added clearer exception, recordkeeping and manager/accountability rules.
6.7	Prior controlled release	Refreshed operational workflows, conditional rules and cross-document handoffs.
7.0	2026-08-01	Current release aligned to enterprise governance baseline and approved process design.

Precedence: This document controls only within its approved subject. Specialist policies, standards and procedures control detailed requirements in their own subject matter; unresolved conflicts are escalated to the relevant Policy Owners.

Table of Contents

1 Purpose, Scope and Standard Authority
- 1.1 Applicability
- 1.2 Mandatory nature of standard
- 1.3 Relationship to SEC-POL-01
- 1.4 Client systems and stricter requirements

2 Identity Governance Roles and Systems of Record
- 2.1 PeopleHub lifecycle source
- 2.2 AccessHub identity source
- 2.3 System Owners
- 2.4 IAM/PAM operations
- 2.5 Manager and Business Owner roles
- 2.6 Orbit Service Desk

3 Identity and Account Types
- 3.1 Workforce accounts
- 3.2 Privileged Accounts
- 3.3 Service Accounts
- 3.4 Temporary Accounts
- 3.5 External/vendor identities
- 3.6 Shared account prohibition and narrowly controlled exceptions

4 Joiner, Mover and Leaver Identity Lifecycle
- 4.1 Joiner provisioning
- 4.2 Role changes
- 4.3 Project/client moves
- 4.4 Standard leavers
- 4.5 Urgent termination/suspension
- 4.6 Orphaned account reconciliation

5 Authentication, Passwords and MFA
- 5.1 Credential ownership
- 5.2 Password requirements
- 5.3 PassLock Enterprise
- 5.4 MFA enrollment
- 5.5 Recovery methods
- 5.6 Credential sharing prohibition
- 5.7 Authentication exceptions

6 RBAC, Least Privilege and Access Design
- 6.1 Role-based access
- 6.2 Need-to-know
- 6.3 Segregation of duties
- 6.4 Birthright versus requested access
- 6.5 Sensitive-data access
- 6.6 Access design review

7 Privileged Access Management
- 7.1 Privileged Account issuance
- 7.2 KeyFort controls
- 7.3 Session management
- 7.4 Just-in-time/temporary privilege
- 7.5 Break-glass access
- 7.6 Privileged review

8 Service Accounts, API Keys and Machine Identities
- 8.1 Ownership
- 8.2 Credential storage
- 8.3 Rotation
- 8.4 Interactive use prohibition
- 8.5 Access scope
- 8.6 Retirement and transfer

9 Contractor, Consultant, Vendor and Temporary Access

9.1 Sponsor requirement
9.2 Expiry
9.3 Vendor lifecycle dependency
9.4 Client access
9.5 Device restrictions
9.6 Departure/termination

10 Access Requests, Approvals and Fulfilment

10.1 Request initiation
10.2 Manager approval
10.3 System/Data Owner approval
10.4 Specialist concurrence
10.5 Conflicted approvals
10.6 Fulfilment and evidence

11 Access Recertification

11.1 Review frequency framework
11.2 Reviewer responsibilities
11.3 Privileged/sensitive access
11.4 Non-response escalation

Table of Contents - continued

11.5 Removal and evidence

12 Suspension, Emergency Access and Account Recovery

12.1 Security suspension
12.2 Employment suspension boundary
12.3 Account lockout/recovery
12.4 Break-glass process
12.5 Incident-response coordination

13 Corporate Devices and Endpoint Use

13.1 Managed devices
13.2 DeviceCentral compliance
13.3 Local admin rights
13.4 Screen locking
13.5 Physical protection
13.6 Lost/stolen devices

14 Internet, Email and Collaboration Use

14.1 Business and limited personal use
14.2 Prohibited use
14.3 External email
14.4 Aurelius Workspace
14.5 File sharing
14.6 Monitoring notice boundary

15 Software Installation, SaaS and Cloud Storage

15.1 Approved software
15.2 Installation rights
15.3 SaaS onboarding
15.4 Personal cloud storage
15.5 Browser extensions
15.6 Shadow IT
15.7 Procurement handoff

16 BYOD and Mobile Access

16.1 Permitted BYOD scope
16.2 Enrollment and controls
16.3 Data separation
16.4 Loss/theft
16.5 Withdrawal of permission

17 USB, Removable Media and Peripheral Devices

17.1 Default restrictions
17.2 Approved removable media
17.3 Encryption
17.4 DataGuard controls
17.5 Client exceptions

18 Remote Work, VPN and Client Connectivity

18.1 Remote access
18.2 VPN
18.3 Home/shared networks
18.4 Public networks
18.5 Client VPNs and jump hosts
18.6 Remote privileged work

19 GenAI, AI Tools and Automated Agents

19.1 Approved AI tools
19.2 Public AI services
19.3 Enterprise AI Service access
19.4 Credentials and API keys
19.5 AI agents and tool permissions
19.6 AI governance handoff

20 Technology Monitoring, Privacy and Audit Logging

20.1 Security/operational monitoring
20.2 Access to monitoring data
20.3 Audit logs
20.4 Privacy governance boundary
20.5 Worker notice references

21 Violations, Security Events and Reporting

21.1 Access/technology violations
21.2 Suspected compromise
21.3 Lost credentials
21.4 Immediate SOC reporting
21.5 Conduct referral

22 Exceptions, Compensating Controls and Review

22.1 Exception criteria
22.2 Security concurrence
22.3 Owner approval
22.4 Expiry
22.5 Periodic review
22.6 Revocation

Document Governance and Use

Define mandatory identity/access controls and acceptable technology use for identities, accounts, endpoints, SaaS, remote work and company/client technology environments.

Provisioning, RBAC, least privilege, privileged/service/temporary/contractor accounts, password managers, MFA, recertification, suspension, termination, device/internet/email use, SaaS, BYOD, software installation, cloud storage, USB, remote work, GenAI tools and prohibited technology use.

Audience: All workers; People Managers; system owners; IAM/PAM operators; Corporate Technology; Security; application owners; vendor managers.

Controlled-source rule: Convenience copies, email extracts, screenshots and local notes do not supersede the controlled document or authoritative enterprise system for the relevant fact.

IAM-STD-03-DG01 - Document Dependencies

Dependency type	Documents
Primary	
Control	

1 Purpose, Scope and Standard Authority

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 1 Purpose, Scope and Standard Authority | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Purpose, Scope and Standard Authority establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

1.1 Applicability

Applicability is governed as part of Purpose, Scope and Standard Authority. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for applicability must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

1.2 Mandatory nature of standard

Mandatory nature of standard is governed as part of Purpose, Scope and Standard Authority. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for mandatory, nature, standard must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

1.3 Relationship to SEC-POL-01

Relationship to SEC-POL-01 is governed as part of Purpose, Scope and Standard Authority. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for relationship must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Information Security Policy & Procedures Manual (SEC-POL-01) §5 - Security identity baseline. This reference supplements this section and does not transfer ownership of unrelated rules.

1.4 Client systems and stricter requirements

Client systems and stricter requirements is governed as part of Purpose, Scope and Standard Authority. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for client, systems, stricter, requirements must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2 Identity Governance Roles and Systems of Record

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 2 Identity Governance Roles and Systems of Record | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Identity Governance Roles and Systems of Record establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

2.1 PeopleHub lifecycle source

PeopleHub lifecycle source is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for peoplehub, lifecycle, source must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.2 AccessHub identity source

AccessHub identity source is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for accesshub, identity, source must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.3 System Owners

System Owners is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for system, owners must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.4 IAM/PAM operations

IAM/PAM operations is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for operations must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.5 Manager and Business Owner roles

Manager and Business Owner roles is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for manager, business, owner, roles must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.6 Orbit Service Desk

Orbit Service Desk is governed as part of Identity Governance Roles and Systems of Record. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for orbit, service must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S01: Teammate asks to use another employee's login during an emergency. Do not share credentials. Use AccessHub/KeyFort emergency or delegated-access procedures and report suspected compromise. Operational urgency changes the escalation path, not the requirement for individual accountability.

3 Identity and Account Types

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 3 Identity and Account Types | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Identity and Account Types establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

3.1 Workforce accounts

Workforce accounts is governed as part of Identity and Account Types. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for workforce, accounts must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.2 Privileged Accounts

Privileged Accounts is governed as part of Identity and Account Types. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for privileged, accounts must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T01 - Identity Type Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

3.3 Service Accounts

Machine identities must have a named System Owner, a defined purpose and the minimum technical permissions required. Secrets are stored in approved managed secret stores; embedding secrets in source code, tickets, documents or chat messages is prohibited. High-risk service-account credentials are rotated at least every 90 days or automatically where supported.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for service, accounts must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.4 Temporary Accounts

Non-employee access must have an end date not later than the approved engagement end date. AccessHub requires a sponsor, a business purpose and a renewal decision before extension. Shared vendor accounts are not permitted when individual accountability is technically feasible.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for temporary, accounts must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.5 External/vendor identities

Non-employee access must have an end date not later than the approved engagement end date. AccessHub requires a sponsor, a business purpose and a renewal decision before extension. Shared vendor accounts are not permitted when individual accountability is technically feasible.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for external, vendor, identities must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.6 Shared account prohibition and narrowly controlled exceptions

Shared account prohibition and narrowly controlled exceptions is governed as part of Identity and Account Types. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for shared, account, prohibition, narrowly must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4 Joiner, Mover and Leaver Identity Lifecycle

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 4 Joiner, Mover and Leaver Identity Lifecycle | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Joiner, Mover and Leaver Identity Lifecycle establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

4.1 Joiner provisioning

Joiner provisioning is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for joiner, provisioning must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T02 - Joiner-Mover-Leaver Access Timing Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

4.2 Role changes

Role changes is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for changes must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4.3 Project/client moves

Project/client moves is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for project, client, moves must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S02: Manager requests access for a new hire before PeopleHub status is active. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

4.4 Standard leavers

Standard leavers is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for standard, leavers must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Onboarding, Internal Transfer & Offboarding SOP (HR-SOP-06) §15 - Urgent/standard leaver trigger. This reference supplements this section and does not transfer ownership of unrelated rules.

4.5 Urgent termination/suspension

Urgent termination/suspension is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for urgent, termination, suspension must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4.6 Orphaned account reconciliation

Orphaned account reconciliation is governed as part of Joiner, Mover and Leaver Identity Lifecycle. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for orphaned, account, reconciliation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4 Joiner, Mover and Leaver Identity Lifecycle - continued

5 Authentication, Passwords and MFA

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 5 Authentication, Passwords and MFA | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Authentication, Passwords and MFA establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

5.1 Credential ownership

Credential ownership is governed as part of Authentication, Passwords and MFA. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for credential, ownership must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T03 - Authentication/MFA Control Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

5.2 Password requirements

Enterprise accounts require MFA wherever the service supports it and for all remote access, privileged access and enterprise SaaS. Passwords must be at least 14 characters and should be unique passphrases stored in PassLock Enterprise. Periodic password changes are not required solely by age; change is required after suspected compromise, recovery, administrative reset or a control-specific rotation event.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for password, requirements must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Credentials are personal and must never be shared, even during an emergency.
- Approved break-glass or delegated-access procedures must be used when continuity requires urgent access.
- MFA prompts must be rejected and reported when the user did not initiate the authentication attempt.
- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.

5.3 PassLock Enterprise

PassLock Enterprise is governed as part of Authentication, Passwords and MFA. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for passlock, enterprise must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S03: Employee changes projects but retains privileged access from the old project. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

5.4 MFA enrollment

Enterprise accounts require MFA wherever the service supports it and for all remote access, privileged access and enterprise SaaS. Passwords must be at least 14 characters and should be unique passphrases stored in PassLock Enterprise. Periodic password changes are not required solely by age; change is required after suspected compromise, recovery, administrative reset or a control-specific rotation event.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for enrollment must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Credentials are personal and must never be shared, even during an emergency.
- Approved break-glass or delegated-access procedures must be used when continuity requires urgent access.
- MFA prompts must be rejected and reported when the user did not initiate the authentication attempt.
- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.

5.5 Recovery methods

Recovery methods is governed as part of Authentication, Passwords and MFA. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for recovery, methods must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.6 Credential sharing prohibition

Credential sharing prohibition is governed as part of Authentication, Passwords and MFA. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for credential, sharing, prohibition must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.7 Authentication exceptions

Enterprise accounts require MFA wherever the service supports it and for all remote access, privileged access and enterprise SaaS. Passwords must be at least 14 characters and should be unique passphrases stored in PassLock Enterprise. Periodic password changes are not required solely by age; change is required after suspected compromise, recovery, administrative reset or a control-specific rotation event.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for authentication, exceptions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Credentials are personal and must never be shared, even during an emergency.
- Approved break-glass or delegated-access procedures must be used when continuity requires urgent access.
- MFA prompts must be rejected and reported when the user did not initiate the authentication attempt.
- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.

6 RBAC, Least Privilege and Access Design

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 6 RBAC, Least Privilege and Access Design | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

RBAC, Least Privilege and Access Design establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

6.1 Role-based access

Role-based access is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for based, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.2 Need-to-know

Need-to-know is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for this activity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.3 Segregation of duties

Segregation of duties is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for segregation, duties must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S04: Contractor's end date is extended but AccessHub expiry is not updated. The sponsor triggers the departure immediately; IAM suspends access under IAM-STD-03; Vendor Management coordinates the supplier action; Security is engaged if the departure is unexplained or suspicious. Client-data access is not left active merely because paperwork is incomplete.

6.4 Birthright versus requested access

Birthright versus requested access is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for birthright, versus, requested, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.5 Sensitive-data access

Sensitive-data access is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for sensitive, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.6 Access design review

Access design review is governed as part of RBAC, Least Privilege and Access Design. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for access, design, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7 Privileged Access Management

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 7 Privileged Access Management | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Privileged Access Management establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

7.1 Privileged Account issuance

Privileged Account issuance is governed as part of Privileged Access Management. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for privileged, account, issuance must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T05 - Privileged Access Decision Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

7.2 KeyFort controls

KeyFort controls is governed as part of Privileged Access Management. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for keyfort, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.3 Session management

Session management is governed as part of Privileged Access Management. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for session, management must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.4 Just-in-time/temporary privilege

Non-employee access must have an end date not later than the approved engagement end date. AccessHub requires a sponsor, a business purpose and a renewal decision before extension. Shared vendor accounts are not permitted when individual accountability is technically feasible.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for temporary, privilege must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S05: Service account has no active human owner after a team reorganization. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

7.5 Break-glass access

Break-glass access is governed as part of Privileged Access Management. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for break, glass, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.6 Privileged review

Privileged review is governed as part of Privileged Access Management. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for privileged, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7 Privileged Access Management - continued

8 Service Accounts, API Keys and Machine Identities

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 8 Service Accounts, API Keys and Machine Identities | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Service Accounts, API Keys and Machine Identities establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

8.1 Ownership

Ownership is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for ownership must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.2 Credential storage

Credential storage is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for credential, storage must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T06 - Service Account Ownership Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

8.3 Rotation

Rotation is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for rotation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.4 Interactive use prohibition

Interactive use prohibition is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for interactive, prohibition must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.5 Access scope

Access scope is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for access, scope must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.6 Retirement and transfer

Retirement and transfer is governed as part of Service Accounts, API Keys and Machine Identities. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for retirement, transfer must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S06: Administrator needs break-glass access during a SEV-1 incident. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

9 Contractor, Consultant, Vendor and Temporary Access

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 9 Contractor, Consultant, Vendor and Temporary Access | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Contractor, Consultant, Vendor and Temporary Access establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

9.1 Sponsor requirement

Sponsor requirement is governed as part of Contractor, Consultant, Vendor and Temporary Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for sponsor, requirement must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T07 - External/Vendor Access Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

9.2 Expiry

Expiry is governed as part of Contractor, Consultant, Vendor and Temporary Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for expiry must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.3 Vendor lifecycle dependency

Non-employee access must have an end date not later than the approved engagement end date. AccessHub requires a sponsor, a business purpose and a renewal decision before extension. Shared vendor accounts are not permitted when individual accountability is technically feasible.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for vendor, lifecycle, dependency must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Procurement, Vendor & Third-Party Risk Management Policy (PROC-TPRM-11) §12 - Vendor access lifecycle. This reference supplements this section and does not transfer ownership of unrelated rules.

9.4 Client access

Client access is governed as part of Contractor, Consultant, Vendor and Temporary Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for client, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.5 Device restrictions

Device restrictions is governed as part of Contractor, Consultant, Vendor and Temporary Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for device, restrictions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.6 Departure/termination

Departure/termination is governed as part of Contractor, Consultant, Vendor and Temporary Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for departure, termination must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10 Access Requests, Approvals and Fulfilment

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 10 Access Requests, Approvals and Fulfilment | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Access Requests, Approvals and Fulfilment establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

10.1 Request initiation

Request initiation is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for request, initiation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.2 Manager approval

Manager approval is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for manager, approval must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T04 - Access Approval Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

Operational scenario S07: Employee wants to install an unapproved browser extension. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

10.3 System/Data Owner approval

System/Data Owner approval is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for system, owner, approval must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.4 Specialist concurrence

Specialist concurrence is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for specialist, concurrence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.5 Conflicted approvals

Conflicted approvals is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for conflicted, approvals must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.6 Fulfilment and evidence

Fulfilment and evidence is governed as part of Access Requests, Approvals and Fulfilment. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for fulfilment, evidence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11 Access Recertification

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 11 Access Recertification | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Access Recertification establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

11.1 Review frequency framework

Review frequency framework is governed as part of Access Recertification. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for review, frequency, framework must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.2 Reviewer responsibilities

Reviewer responsibilities is governed as part of Access Recertification. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for reviewer, responsibilities must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T08 - Access Recertification Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

11.3 Privileged/sensitive access

Privileged/sensitive access is governed as part of Access Recertification. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for privileged, sensitive, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.4 Non-response escalation

Non-response escalation is governed as part of Access Recertification. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for response, escalation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S08: Worker uploads corporate files to a personal cloud drive. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

11.5 Removal and evidence

Removal and evidence is governed as part of Access Recertification. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for removal, evidence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12 Suspension, Emergency Access and Account Recovery

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 12 Suspension, Emergency Access and Account Recovery | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Suspension, Emergency Access and Account Recovery establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

12.1 Security suspension

Security suspension is governed as part of Suspension, Emergency Access and Account Recovery. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for security, suspension must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.2 Employment suspension boundary

Employment suspension boundary is governed as part of Suspension, Emergency Access and Account Recovery. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for employment, suspension, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.3 Account lockout/recovery

Account lockout/recovery is governed as part of Suspension, Emergency Access and Account Recovery. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for account, lockout, recovery must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.4 Break-glass process

Break-glass process is governed as part of Suspension, Emergency Access and Account Recovery. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for break, glass, process must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.5 Incident-response coordination

Incident-response coordination is governed as part of Suspension, Emergency Access and Account Recovery. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for incident, response, coordination must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Security Incident Response & Business Continuity Manual (SEC-IR-004) §8 - Incident-response credential actions. This reference supplements this section and does not transfer ownership of unrelated rules.

13 Corporate Devices and Endpoint Use

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 13 Corporate Devices and Endpoint Use | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Corporate Devices and Endpoint Use establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

13.1 Managed devices

Managed devices is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for managed, devices must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.2 DeviceCentral compliance

DeviceCentral compliance is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for devicecentral, compliance must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.3 Local admin rights

Local admin rights is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for local, admin, rights must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S09: BYOD phone is lost with corporate access configured. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

13.4 Screen locking

Screen locking is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for screen, locking must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.5 Physical protection

Physical protection is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for physical, protection must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.6 Lost/stolen devices

Lost/stolen devices is governed as part of Corporate Devices and Endpoint Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for stolen, devices must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14 Internet, Email and Collaboration Use

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 14 Internet, Email and Collaboration Use | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Internet, Email and Collaboration Use establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

14.1 Business and limited personal use

Business and limited personal use is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for business, limited, personal must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.2 Prohibited use

Prohibited use is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for prohibited must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T09 - Acceptable Technology Use Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

14.3 External email

External email is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for external, email must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.4 Aurelius Workspace

Aurelius Workspace is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for aurelius, workspace must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.5 File sharing

File sharing is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for sharing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.6 Monitoring notice boundary

Monitoring notice boundary is governed as part of Internet, Email and Collaboration Use. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for monitoring, notice, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15 Software Installation, SaaS and Cloud Storage

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 15 Software Installation, SaaS and Cloud Storage | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Software Installation, SaaS and Cloud Storage establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

15.1 Approved software

Approved software is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for approved, software must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.2 Installation rights

Installation rights is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for installation, rights must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S10: Public LLM requires user to paste an API token. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

15.3 SaaS onboarding

SaaS onboarding is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for onboarding must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.4 Personal cloud storage

Personal cloud storage is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for personal, cloud, storage must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.5 Browser extensions

Browser extensions is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for browser, extensions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.6 Shadow IT

Shadow IT is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for shadow must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.7 Procurement handoff

Procurement handoff is governed as part of Software Installation, SaaS and Cloud Storage. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for procurement, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16 BYOD and Mobile Access

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 16 BYOD and Mobile Access | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

BYOD and Mobile Access establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

16.1 Permitted BYOD scope

BYOD access is limited to approved services and requires DeviceCentral enrollment or another approved management control. RESTRICTED information may not be stored on a personally owned device. Loss of a BYOD device with company access must be reported immediately so company data can be selectively protected or removed.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for permitted, scope must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16.2 Enrollment and controls

Enrollment and controls is governed as part of BYOD and Mobile Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for enrollment, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T10 - BYOD Control Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

16.3 Data separation

Data separation is governed as part of BYOD and Mobile Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for separation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16.4 Loss/theft

Loss/theft is governed as part of BYOD and Mobile Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for theft must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S11: AI agent is configured with broad production permissions. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

16.5 Withdrawal of permission

Withdrawal of permission is governed as part of BYOD and Mobile Access. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for withdrawal, permission must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17 USB, Removable Media and Peripheral Devices

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 17 USB, Removable Media and Peripheral Devices | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

USB, Removable Media and Peripheral Devices establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

17.1 Default restrictions

Default restrictions is governed as part of USB, Removable Media and Peripheral Devices. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for default, restrictions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.2 Approved removable media

Approved removable media is governed as part of USB, Removable Media and Peripheral Devices. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for approved, removable, media must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.3 Encryption

Encryption is governed as part of USB, Removable Media and Peripheral Devices. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for encryption must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.4 DataGuard controls

DataGuard controls is governed as part of USB, Removable Media and Peripheral Devices. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for dataguard, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.5 Client exceptions

Client exceptions is governed as part of USB, Removable Media and Peripheral Devices. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for client, exceptions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18 Remote Work, VPN and Client Connectivity

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 18 Remote Work, VPN and Client Connectivity | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Remote Work, VPN and Client Connectivity establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

18.1 Remote access

Remote access is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for remote, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.2 VPN

VPN is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for this activity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.3 Home/shared networks

Home/shared networks is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for shared, networks must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.4 Public networks

Public networks is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for public, networks must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.5 Client VPNs and jump hosts

Client VPNs and jump hosts is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for client, hosts must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S12: Access recertification reviewer ignores the review request. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

18.6 Remote privileged work

Remote privileged work is governed as part of Remote Work, VPN and Client Connectivity. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for remote, privileged must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19 GenAI, AI Tools and Automated Agents

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 19 GenAI, AI Tools and Automated Agents | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

GenAI, AI Tools and Automated Agents establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

19.1 Approved AI tools

Technology approval does not by itself approve a particular AI use case or data type. Only tools and uses approved under AI-GOV-05 may be used for company work. Public AI services may not receive credentials, client data, CONFIDENTIAL information or RESTRICTED information.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for approved, tools must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.2 Public AI services

Public AI services is governed as part of GenAI, AI Tools and Automated Agents. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for public, services must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T11 - AI Tool Access Matrix

Access type	Approval	Review cadence	Key condition
Standard role access	LM + System Owner workflow	At least 6-monthly	Business role required
Privileged access	System Owner + PAM control	At least quarterly	Time-bound elevation
Contractor/vendor access	Sponsor + System Owner	End-date + review	Expires with engagement
Emergency access	Incident/emergency process	Post-use review	No credential sharing

19.3 Enterprise AI Service access

Enterprise AI Service access is governed as part of GenAI, AI Tools and Automated Agents. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for enterprise, service, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.4 Credentials and API keys

Machine identities must have a named System Owner, a defined purpose and the minimum technical permissions required. Secrets are stored in approved managed secret stores; embedding secrets in source code, tickets, documents or chat messages is prohibited. High-risk service-account credentials are rotated at least every 90 days or automatically where supported.

Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for credentials must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.5 AI agents and tool permissions

AI agents and tool permissions is governed as part of GenAI, AI Tools and Automated Agents. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for agents, permissions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.6 AI governance handoff

AI governance handoff is governed as part of GenAI, AI Tools and Automated Agents. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for governance, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: AI, Machine Learning & Generative AI Governance Standard (AI-GOV-05) §4 - AI use approval/prohibition. This reference supplements this section and does not transfer ownership of unrelated rules.

20 Technology Monitoring, Privacy and Audit Logging

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 20 Technology Monitoring, Privacy and Audit Logging | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Technology Monitoring, Privacy and Audit Logging establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

20.1 Security/operational monitoring

Security/operational monitoring is governed as part of Technology Monitoring, Privacy and Audit Logging. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for security, operational, monitoring must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.2 Access to monitoring data

Access to monitoring data is governed as part of Technology Monitoring, Privacy and Audit Logging. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for access, monitoring must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S13: Employee asks for local admin rights to run a development tool. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

20.3 Audit logs

Audit logs is governed as part of Technology Monitoring, Privacy and Audit Logging. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for audit must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.4 Privacy governance boundary

Privacy governance boundary is governed as part of Technology Monitoring, Privacy and Audit Logging. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for privacy, governance, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Information Security Policy & Procedures Manual (SEC-POL-01) §13 - Security logging, monitoring and telemetry baseline. This reference supplements this section and does not transfer ownership of unrelated rules.

Related controlled source: Data Privacy & Data Governance Policy (PRIV-DG-02) §12 - Privacy governance for employee monitoring, logs and telemetry; cross-reference only, not a formal dependency. This reference supplements this section and does not transfer ownership of unrelated rules.

20.5 Worker notice references

Worker notice references is governed as part of Technology Monitoring, Privacy and Audit Logging. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for worker, notice, references must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21 Violations, Security Events and Reporting

Violations, Security Events and Reporting establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

21.1 Access/technology violations

Access/technology violations is governed as part of Violations, Security Events and Reporting. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for access, technology, violations must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.2 Suspected compromise

Suspected compromise is governed as part of Violations, Security Events and Reporting. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for suspected, compromise must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.3 Lost credentials

Lost credentials is governed as part of Violations, Security Events and Reporting. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for credentials must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.4 Immediate SOC reporting

Immediate SOC reporting is governed as part of Violations, Security Events and Reporting. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for immediate, reporting must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.5 Conduct referral

Conduct referral is governed as part of Violations, Security Events and Reporting. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for conduct, referral must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22 Exceptions, Compensating Controls and Review

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section 22 Exceptions, Compensating Controls and Review | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

Exceptions, Compensating Controls and Review establishes the requirements, responsibilities and decision rules that apply within this part of Identity, Access Management & Acceptable Technology Use Standard. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

22.1 Exception criteria

Exception criteria is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for exception, criteria must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.2 Security concurrence

Security concurrence is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for security, concurrence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

IAM-STD-03-T12 - IAM Exception Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

22.3 Owner approval

Owner approval is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for owner, approval must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S14: Vendor personnel leaves unexpectedly while holding client access. Apply the requirements in Identity, Access Management & Acceptable Technology Use Standard to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

22.4 Expiry

Expiry is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for expiry must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.5 Periodic review

Periodic review is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for periodic, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.6 Revocation

Revocation is governed as part of Exceptions, Compensating Controls and Review. Access is granted to named identities for approved business purposes and must remain no broader or longer than required.

Implementation for revocation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. System Owners and IAM Operations must preserve individual accountability, least privilege and timely removal throughout the identity lifecycle.

- Requesters explain business need; approvers confirm role need; IAM fulfils approved access.
- System Owners define access models and review entitlements.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Appendices, Forms and Checklists

Identity, Access Management & Acceptable Technology Use Standard | IAM-STD-03 | v7.0 | Effective 2026-08-01 | Section Appendices Controlled execution aids | Corporate Technology & Workplace IT / Information Security & Resilience | CONFIDENTIAL

IAM-STD-03-AA IAM and Technology Use Definitions

Term	Controlled meaning
Credential	Authentication information used to prove identity or authorize access, including passwords, tokens, certificates, private keys, recovery codes, and equivalent secrets.
Security Incident	Security event or series of events that compromises, or credibly threatens to compromise, confidentiality, integrity, availability, authentication, or control of company/client resources.
Privacy Incident	Event involving unauthorized or inappropriate collection, access, use, disclosure, alteration, loss, retention, or deletion of Personal Data; may also be a Security Incident.
Major Incident	SEV-1 incident, or a designated SEV-2 incident, requiring coordinated cross-functional incident management.
Corporate Device	Endpoint owned or company-managed by Aurelius and enrolled in required management/security controls.
BYOD	Personally owned device permitted for limited company access under IAM-STD-03 and device-management conditions.
Record	Information retained as evidence of a business decision, transaction, approval, obligation, incident, or controlled activity.
Source of Truth	Designated authoritative system or controlled document for a particular fact or process. Convenience copies do not override it.

IAM-STD-03-AB Access Request Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

IAM-STD-03-AC Privileged Access Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

IAM-STD-03-AD Service Account Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

IAM-STD-03-AE Leaver Access Closure Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

IAM-STD-03-AF Acceptable Technology Use Quick Guide

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

IAM-STD-03-F01 Access Exception Request

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

IAM-STD-03-F02 Temporary Access Request

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

IAM-STD-03-F03 Service Account Ownership Record

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Identity, Access Management & Acceptable Technology Use Standard.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.